Policy and Metrics

Joseph Maguire

Enterprise Cyber Security

Overview

- What a **policy** is, why an organisation needs one, and how to write one that people can follow.
- Why **metrics** matter, what makes a metric **good**, and where metrics go wrong.
- How **metrics** show whether a policy is working.
- What this means for your **team assessed exercise**.


POLICY
METRICS
SUMMARY

Where we left Aldermoor

The risk assessment

- The risk assessment found that a **password-only remote login** for a contractor was a way into Aldermoor's systems.
- The board must decide what Aldermoor should **require**, and how it will know that the requirement is **met**.
- Today: what a policy is, how to write one, and how **metrics** show whether it works.


POLICY
METRICS
SUMMARY

What a policy is

A policy codifies objectives

The blueprint for the approach

- Cyber security policy codifies the **objectives** of an organisation, to support the **behaviour** needed to reach them.
- Objectives do not translate directly into behaviour. The policy is the **blueprint** for the overall approach.
- A policy is **instructions from management** on the expected governance of the organisation.

Goals, not specifications

What a policy leaves out

- Policies present **security goals**, rather than **specifications**.
- Policies may require documentation of **implementation**, but implementation should not form part of the policy.
- A policy should **endure for several years**. It names no specific technology and gives no implementation details.

Policies are not procedures or controls

Different things, different levels

- A policy is not a step-by-step instruction, such as how to duplicate a data repository.
- A policy is not a **control**. A control can meet a policy directive: a declaration form can meet a ban on conflicts of interest.
- A policy may still name the controls that are required.

Where policy comes from

Governance and management

- Several UK enterprises collapsed in the 1980s, and the state questioned how organisations were managed and governed.
- BCCI was forced to close because of poor management.
- The 1992 **Cadbury Report** recommended ways to minimise threats to assets from poor management.

Cadbury Report (1992).
Committee on the Financial Aspects of Corporate Governance (1992) *Report of the Committee on the Financial Aspects of Corporate Governance* (the Cadbury Report). December 1992. Available at:
https://www.jbs.cam.ac.uk/faculty-research/publications/cadbury-archive/report/.

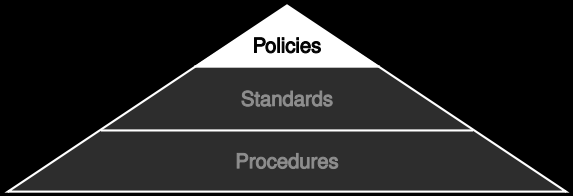
Who governs the policy?

The governing body shapes it

- The **governing body** sets the aims of a policy, and each policy applies to a specific realm.
- The governing body also influences how the policy is produced.
- Different units may govern different policies, which can create **conflicts and overlaps**.

Hierarchy of governance

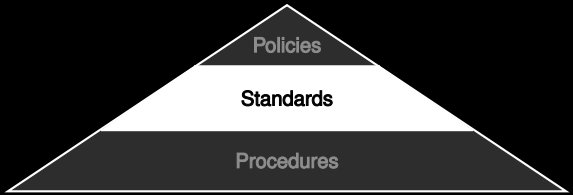
Policies: the what



- **Policies** set the high-level objectives and the directives that reduce and minimise risk.
- They say **what** must happen, not how. Example: contractors must use authorised, protected remote access.

Hierarchy of governance

Standards: the how

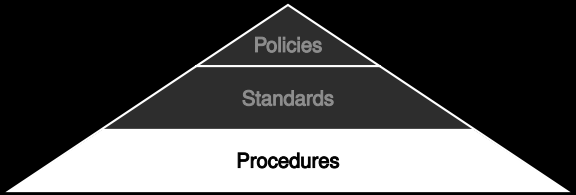


- **Standards** are the specific rules that meet the policy. They are technology-specific, but not step-by-step.
- **Password example**: MFA for important and internet-facing accounts. A minimum length (NCSC gives no number, so Aldermoor sets one), no maximum length, and no forced regular change.

NCSC guidance (2018). Full reference on the next slide.

Hierarchy of governance

Procedures: the steps



- **Procedures** are the detailed steps staff follow, at implementation level.
- **Password example**: check each new password against a **deny list** of common passwords, and reject a match. Where real-time checks are not possible, you might be able to search stored password hashes for deny-listed passwords.

NCSC guidance (2018). Full reference on the next slide.

One password, three levels

Worked example from NCSC guidance

Level	Example
Policy	Contractors must use authorised, protected remote access.
Standard	MFA for important and internet-facing accounts. A minimum length, no maximum length, no forced regular change, and a change when a compromise is known or suspected.
Procedure	Check new passwords against a deny list of common passwords. Lock inactive accounts, run leaver processes and monitor for suspicious logins.

NCSC Guidance

National Cyber Security Centre (2018) *Password policy: updating your approach*. Reviewed 19 November 2018. Available at: https://www.ncsc.gov.uk/collection/passwords/updating-your-approach.

Why have a policy?
Motivations, part 1

- **Consistency**: policies reduce inconsistent behaviour, and give consistent responses to problems.
- **Controls and products**: buying a product is not enough. Policy guides selection and deployment.
- **Distribution of knowledge**: policies tell staff what they need to know. Expert knowledge is little use if no one else has it.
- **Expectations**: policies set boundaries, and give a foundation for disciplinary action.

Why have a policy?
Motivations, part 2

- **Compliance and audit**: writing a policy considers legal and regulatory concerns, and regulators often expect policies to exist.
- **Avoiding liability**: a policy shows the organisation has considered its security and performed due diligence.
- **Tone**: policy sets the tone for security that employees project.
- **Management endorsement**: a policy that management does not support is unlikely to succeed.

ISO/IEC 27001:2022, clause 5.2, requires top management to establish an information security policy.
ISO/IEC 27001:2022 *Information security, cybersecurity and privacy protection: Information security management systems: Requirements.* Geneva: ISO/IEC.

Consistency has a cost

Autonomy

- Policy reduces the autonomy of individuals and leaders, so that rules are applied consistently.
- Less autonomy can improve security in one direction, but harm the enterprise or other aspects of security.
- Careless and poorly communicated loss of autonomy is one of the quickest ways to turn valuable employees into insiders.
- Take care over how far a policy should go.

Writing a policy

What a policy document contains

Typical sections

- Scope
- Purpose
- Owner
- Executive sign-off
- Revision detail
- Related documents
- Policy directives
- Roles and responsibilities
- Revision control

Write in clear language

Policies are not optional

Clear and directive	Vague and optional
must, do, will	try, should, consider

- Keep directives **short and simple**. People may ignore a long policy.
- A policy is meant to be read and followed. Limited sentences or bullet points will suffice.

Realistic and lawful

What a directive should be

- Set **realistic** expectations of behaviour.
- Do not write a directive that cannot be enforced. Staff are likely to ignore it.
- Do not make directives difficult or unrealistic to follow.
- Operate within the **legal and regulatory** environment.

Inclusive or exclusive?

Two ways to draw the line

Inclusive

States what is **permitted**. Unknown or new applications and services are prohibited until they are known and added.

Exclusive

States what is **prohibited**. Everything not listed is allowed.

Policies in practice

Example policy titles

- Acceptable Encryption Policy
- Data Breach Response Policy
- Email Retention Policy
- Internet Usage Policy
- Mobile Device Encryption Policy
- Communications Equipment Policy
- Pandemic Response Planning Policy
- Password Construction Guidelines
- Server Security Policy
- Social Engineering Awareness Policy

Example titles only. Check the SANS library for current names.

SANS Institute and Cybersecurity Risk Foundation. *Cybersecurity Policies and Standards*: a library of free cybersecurity and information security policy templates. Available at: https://www.sans.org/information-security-policy (accessed 28 October 2026).

Problems with policies

Policy can do harm

- Many policies cause **confusion** and **lack of clarity**, and can do more harm than good.
- Curbing autonomy can make employees disgruntled, which increases the **insider threat**.
- A policy can impede business objectives, and so interfere with the success of the system.
- Policy often focuses on **risk**, not on how people make decisions or what motivates them.

Make the policy easy to find

Communication

- Employees should be able to access the policy easily. Physical copies may help.
- Top-down communication should focus on the direction and objectives of cyber security, for the key decision makers.

How do we know a policy works?

Verification and validation

- Metrics can determine whether **security objectives** are being met.
- Verification metrics confirm that solutions meet their known requirements.
- Evidence must show that objectives are met. Defending against the latest known attacks is not enough.

POLICY

METRICS

SUMMARY

“Security is a process, not a product”

Bruce Schneier, Crypto-Gram (2000)

The shampoo algorithm

Lather, rinse, repeat

- Organisations keep **repeating** interventions without checking that they work.

The shampoo algorithm

Lather, rinse, repeat

- Organisations keep **repeating** interventions without checking that they work.
- Escaping the loop requires checking whether each intervention works as assumed.

The shampoo algorithm

Lather, rinse, repeat

- Organisations keep **repeating** interventions without checking that they work.
- Escaping the loop requires checking whether each intervention works as assumed.
- **Key indicators**, or metrics, show whether interventions work as expected.

Quantifying risk is harder

Identifying a risk is the easy part

- Asset understanding must be established, which means asking difficult questions.
- The value of each asset must be understood, along with the cost of its controls and how that compares with peers.
- Reaching consensus on even a single question can be a challenge.

What is a metric?

Key performance indicators

Inventory turnover, as an example

Company	Turns	Company	Turns
McDonald's	142.4	Dell	35.6
Apple	74.1	Samsung	17.1
Walmart	8.3	Coca-Cola	5.8
Nike	4.6	Caterpillar	3.4

What makes a metric powerful?

Inventory turnover

- Uses measurements of **time and money**, and is calculated **automatically**.
- Is understood across the enterprise and across the industry, and is **consistently measured**.
- Higher turnover means less obsolete stock. The metric allows comparison across competitors, but is hard to compare across domains.

Measures and metrics

Two different things

- A **measure** is objective and solid. For example, the percentage of systems that have the latest software update.
- A **metric** is subjective to some extent, and focuses on how well systems are secured. It can combine several measurements.
- Measures and metrics define **benchmarks**, which organisations use to improve their systems.

See also: ISO/IEC 27004:2016, monitoring, measurement, analysis and evaluation.

ISO/IEC 27004:2016 *Information technology: Security techniques: Information security management: Monitoring, measurement, analysis and evaluation.* 2nd edn. Geneva: ISO/IEC.

What metrics are for

Enterprise and management

The enterprise

- Verify compliance with policy, standards and procedures.
- Find the strengths and weaknesses of security.
- Compare performance with peers, and track trends.

Management

- Improve the performance of controls and policy.
- Answer important management questions.
- Evaluate policy against compliance and legislation.

Why measure?
Motivations

- Remove **fear, uncertainty and doubt** with strong measurements.
- Demonstrate **regulatory compliance**, for accountability.
- Show that spending is **provable**: understand what the money bought, and justify the **funding** of defences.
- The aim is **insight** into the system as a whole. The hard part is finding the right question.

Business drivers

Four pressures

- **Information asset fragility**: when information is destroyed or leaked, management is concerned.
- **Provable security**: without metrics, organisations spend heavily with little to show for it.
- **Cost pressures**: budgets are finite, and expensive solutions that cannot show effectiveness are unlikely to be funded.
- **Accountability**: metrics make failures and achievements visible, as a speedometer does for speed.

What makes a good metric?

Five characteristics

Good metrics

- **Consistently measured**: two people get the same answer from the same data.

Five characteristics

Good metrics

- **Consistently measured**: two people get the same answer from the same data.
- **Cheap to gather**: quick and inexpensive, so it is collected often.

Five characteristics

Good metrics

- **Consistently measured**: two people get the same answer from the same data.
- **Cheap to gather**: quick and inexpensive, so it is collected often.
- **Expressed as a number**: a count or a percentage, not a rating.

Five characteristics

Good metrics

- **Consistently measured**: two people get the same answer from the same data.
- **Cheap to gather**: quick and inexpensive, so it is collected often.
- **Expressed as a number**: a count or a percentage, not a rating.
- **Expressed using at least one unit**: for example, per 1,000 emails.

Five characteristics

Good metrics

- **Consistently measured**: two people get the same answer from the same data.
- **Cheap to gather**: quick and inexpensive, so it is collected often.
- **Expressed as a number**: a count or a percentage, not a rating.
- **Expressed using at least one unit**: for example, per 1,000 emails.
- **Contextually specific**: tailored to the audience and the system.

Consistent and cheap

Credibility and use

- A consistently measured metric is more **credible**. Two people taking it from the same data should get the same answer.
- A **soft** metric relies on judgement, so two people may rate differently.
- The faster and cheaper a metric is to gather, the more it is used. Automated metrics are collected far more than manual ones.

A number, with a unit, in context

Expressed as a number

- **Counts** are more valuable than ratings or order. A traffic-light rating is not a good metric.
- A unit makes a number meaningful: the number of malicious emails, then the number per 1,000 emails.
- Context makes it useful: the percentage of malicious emails for human resources, not for everyone.

Bad metrics

Three warning signs

- **Inconsistently measured**: soft, judgement-based, and hard to elicit carefully.
- **Cannot be gathered cheaply**: slow metrics are collected rarely, and may be poorly produced.
- **Not expressed in units**: ratings and judgements are ordinal, and generally poor metrics.

Start from the question

Choosing metrics

- The best metrics answer valuable questions. Start from the question, then choose the metrics that answer it.
- Catalogues and frameworks of metrics inspire, but should not be chosen without thought to context.
- A metric that seemed reasonable early on may be pointless later. Review metrics over time.

NIST guidance on identifying and selecting measures.

Schroeder, K., Trinh, H. and Pillitteri, V. (2024) *Measurement Guide for Information Security, Volume 1: Identifying and Selecting Measures*. NIST SP 800-55v1. Available at: https://csrc.nist.gov/pubs/sp/800/55/v1/final.

Metrics for each audience

Management and technical teams

Management

Asks high-level questions, such as: how does our security cost compare with peers?

Technical teams

Need lower-level metrics on specific controls, such as: % of malicious code detected in stored files.

Enterprises should rely on a number of metrics, spread across levels.

Importance and frequency

Jaquith (2007)

	Measured more often	Measured less often
High importance	**Crisis management**: threat metrics, intrusion detection	**Strategic planning**: budgets, resource allocation, compliance, business assets
Lower importance	**Operations management**: anti-malware data, network operations, security operations, maintenance	**Program planning**: resource usage, development lifecycle metrics, auditing and logging analyses

Metrics in practice

Examples: email

Metric, motive, source

Metric	Motive	Source
Encrypted messages per day (%, count)	Understanding the level of encrypted traffic	Email system
Spam false negatives (%, count)	Accuracy of spam defences	Gateway defence solution
Spam false positives (%, count)	Accuracy of spam defences	Gateway defence solution
Virus true positives (%, count)	Accuracy of virus defences	Gateway defence solution

Examples: patch management

Metric, motive, source

Metric	Motive	Source
Number of unapplied patches	Indicator of unapplied workload	Patch management software
Patch SLA achievement	Understanding achievement of the SLA	Time and motion, patch software
Systems not in line with patch policy	Understanding the reach of patch management	Patch and vulnerability management software

Problems with metrics

Accuracy

- A strong-looking metric can still be imprecise. Patch management may be reported at operating-system level or application level.
- Measurement methods must be clear. Third-party data is risky when it is not clear how it was collected.
- Metrics used without context are hard to value, and fluid language can lead to poor interpretation.

Problems with metrics

Selection and combination

- Cheap and easy metrics are favoured, even when their value is unclear. This wastes time and can mislead.
- Staff who see their data as useless may become disgruntled, or doubt the organisation's security.
- Measures must be combined correctly, or the metric is misleading. Review metrics as the organisation improves.

What are not metrics?

Poor metrics do not help

- The aim of metrics is to improve cyber security. Poor metrics do not support that aim.
- Catalogues of metrics inspire, but often they are not useful as they stand.
- Metrics chosen without thought to context should not be used.

Policy in the management cycle

Metrics in the cycle

- Strategy, policy, awareness, control, metrics and reporting form one cycle.
- Metrics verify compliance with policy, standards and procedures.
- A metric such as “systems not in line with patch policy” turns a policy into something that can be checked.
- Revise the policy and its metrics together, as the organisation learns.


POLICY
METRICS
SUMMARY

Summary

- A policy codifies **objectives** as **goals**. It says what must happen, and standards and procedures say how.
- Directives use **clear language**: must, do, will. Keep them short, realistic and lawful.
- Good metrics are **consistent**, cheap, expressed as numbers with a unit, and tied to a question.
- Metrics show whether a policy is working. Revise both over time.

Your team assessed exercise

Policy design

- Design a **policy** to address a specific cyber security concern.
- Communicate the policy, and what informed it, in a **6-page report** to key decision makers.
- Write **clear directives**, and say which **metrics** would show that they are met.

Further reading

Read these after the lecture

Book

Jaquith, A. (2007) *Security Metrics: Replacing Fear, Uncertainty, and Doubt*. 1st edn. Addison-Wesley Professional. Read it for the metrics in more depth.

Articles and standards

- Schneier, B. (2000) Computer Security: Will We Ever Learn? *Crypto-Gram*, 15 May 2000.
- NIST SP 800-55v1 (2024), identifying and selecting measures.
- ISO/IEC 27004:2016, measurement and evaluation.
- ISO/IEC 27001:2022, clause 5.2.

Policy and Metrics

Joseph Maguire

Enterprise Cyber Security